TABLETOP / AGENTIC KUBERNETES GUARDRAILS

FROM INTENT TO ENFORCEMENT

Quarantine Mode

Incident containment on a shared Kubernetes platform



Co-presenters: Milind Gunjan / Vivek Mayuranathan

October 26, 2026 · 4:30–5:30 PM · Views are our own

Security changes during an incident

THE PROBLEM

Services and automated agents share infrastructure and credentials.
Harmful access can cross a workload’s intended boundary.
Broad restrictions can disrupt essential services.

WHAT WE BUILD

A tested change set from written security intent,
with explicit approval and containment boundaries.

Technical briefing first. Then your team reviews a case and defines recovery tests.

The environment in plain language

Kubernetes manages application packages, called containers, across machines.
Payment services and automated agents share this platform.

Application copies	Pods: running units. Replicas: copies.
Resource groups	Namespaces: named groups, such as payments.
Workload identity	ServiceAccount: identity for management API requests.

Multiple services share infrastructure and dependencies.
A restriction for one can affect another.

Detection, prevention and response

Detection	Falco rules flag suspicious runtime activity. Audit logs record Kubernetes API requests.
Admission	Kyverno can deny a new Pod requesting privilege escalation before it starts.
Containment	NetworkPolicy limits traffic. RBAC limits API access. Agent tools need application controls.
Authority	The policy agent proposes controls for review. People authorize containment and recovery.

Denying a new Pod leaves running workloads and copied tokens for separate response.

Falco rules passed validation. Live detection is unverified.
We supply incident alerts. The demo compiles proposals and runs policy tests.

The policy agent decision loop

Stage	Model choice	Python and tools
Map intent	One of 10 catalog options per clause	Validate choice; fill the scoped spec
Dependencies	preserve or deny each profile	Read fixtures; collect workload labels
Blocked workload	allow_and_retest, request_exception or block_is_intended	Render templates; simulate admission; at most 3 rounds
Review bundle	Exception request or escalation	Write stage files, tests, coverage and local PR.md

Python fixes the sequence. Reviewers resolve missing coverage and authorize deployment.

Trust boundaries and model inputs

Boundary	What crosses it
Runtime events	Supplied alerts inform human review. The harness does not ingest Falco.
Provider request	Full intent + clause, profile/workload names, or workload/policy/denial reason
Provider response	Allowed choice + numeric score. Invalid or below 0.6 escalates.
Uncertain dependency	The proposal retains the allowance and flags it for human review.
Cluster change	An operator applies reviewed changes. The presenter path uses fixtures.

Scores are uncalibrated. Credentials need separate least-privilege controls.
Reference and replay make no new model request.

One requirement, one compiled control

Field	Compiled behavior
Intent	Prevent privilege escalation in payments.
Catalog key	deny_privilege_escalation / ACG-POD-001
Generated API	Kyverno ValidatingPolicy, scoped to payments
Covered requests	Pod CREATE; regular and init containers
Required fields	privileged=false and explicit allowPrivilegeEscalation=false

Local bundle: PR.md, stage files, tests, readiness and provenance.
This supplied-spec path makes no model request or deployment.

Unresolved enforcement requirements

Intent clause	Proposal status
Limit east-west communication	Egress-profile policy
Prevent privilege escalation	Privilege policy
Restrict Kubernetes API access	Unimplemented. RBAC handover required.
Avoid disruption and expire exceptions	Rollout and exception process

The independent contract is bound to this prepared intent.
New wording requires its own reviewed contract and acceptance tests.

Quarantine Mode implementation

Level	Mechanisms	Verification required
Q0 Normal	Reviewed baseline guardrails	Legitimate service paths
Q1 Freeze	Native API-server policy freezes writes by identities in agents	Covered writes and allowed reads
Q2 Constrain	NetworkPolicy and protected labels; manual RBAC narrowing	Traffic and API positive/negative tests
Q3 Isolate	Suspect isolation labels + deny-all; Pod CREATE gate	Isolation and clean serving capacity

People apply reviewed manifests and perform identity steps separately.
Quarantine Mode has no automatic Falco-triggered controller here.

Your table’s task

We provide case facts, prepared proposals and enforcement evidence.
You write, review and revise decisions on pages 6-7 before each reveal.

YOUR RECORD ON PAGES 6-7

Intent and approval decision
Exception and rollout conditions
Containment order and recovery tests

YOUR TABLE ROLES

Lead: states the decision
Recorder: keeps the record
Analyst: checks the evidence
Reviewer: raises a concern

Milind and Vivek co-present the demo, reviews and evidence.
Your intent stays on the record. The common demo uses a supplied reference spec.

Four prepared scenarios

A	**Library update**	A library update and unexpected payments traffic
B	**Support assistant**	A ticket-reading assistant and unexpected tool activity
C	**Unexpected changes**	An ops agent changes application copies without a ticket
D	**Credential access**	A monitoring identity lists credential records across groups

Choose as a team. Keep the sealed updates closed until the round opens.

Operational constraints

Availability	Keep two healthy application copies and required connections.
Evidence	Preserve evidence and record every approval.
Velocity	Continue safe delivery while affected changes pause.
Containment	Stop suspected exposure and justify the service cost.

Record your case, roles, constraint and minimum service on page 6.

01

Define the security requirement.



Stop [behavior]. Preserve [dependency].
Example: block new privileged workloads.
Allow approved releases. Write your own on page 6.

Record your review decision

APPROVE

MODIFY

REJECT

ESCALATE

One control to keep or change.

One missing test that could change your decision.

A temporary access request

Read your case’s request. Which operation must continue?
What authority would you grant while approval is checked?

Grant / narrow / hold / refuse.
Record conditions, remaining exposure and one test that could change your answer.

22–26 MINUTES / TEAM TASK

Audit. Warn. Deny.

Mode	Admission behavior	Review question
Audit	Allow and record	Is exposure acceptable while we observe?
Warn	Allow and warn	Who will act on the warning?
Deny	Refuse the change	What legitimate workload could break?

Choose a mode per control and write promotion criteria.

03

Plan scoped containment.

Open the sealed update on page 8.
Number actions and state the service floor.



Reassess with additional evidence

REVISE THE PLAN / ESCALATE / JUSTIFY NO CHANGE

Record which new evidence changes the scope or action order.

Validate the containment assumptions

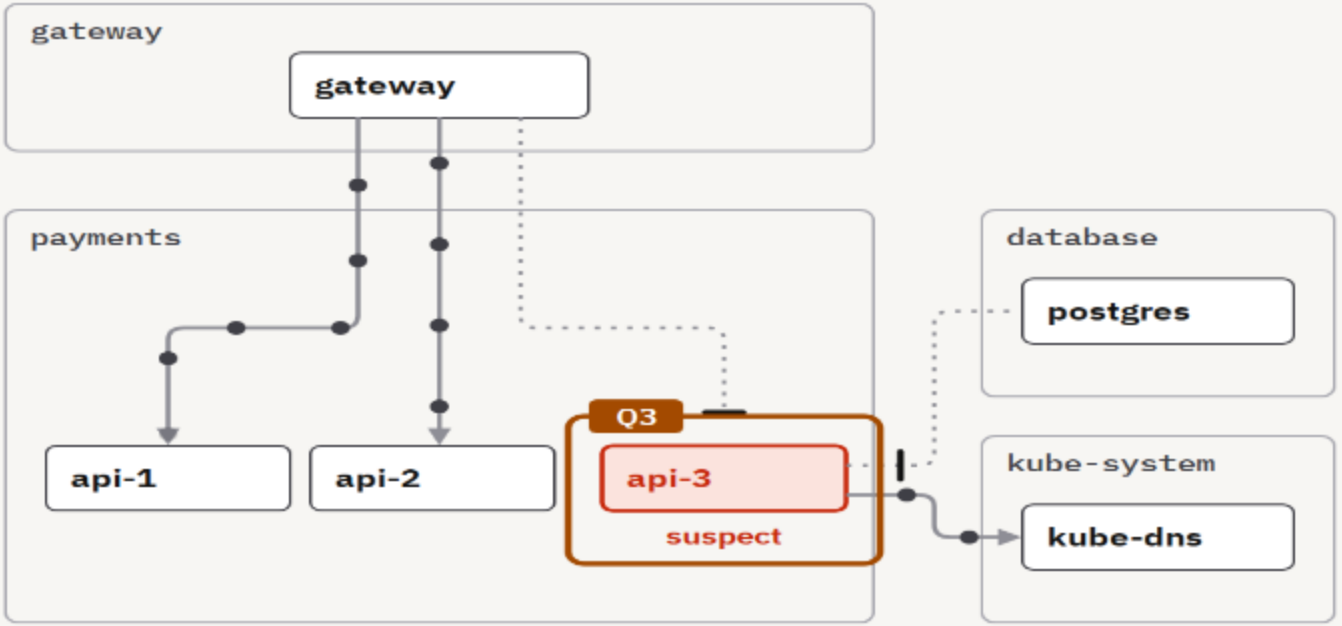
NETWORK Does deny-all remove an existing allow?

RECOVERY Can eviction preserve evidence and healthy capacity?

AUTHORITY Which identity or API path can bypass your plan?

Real k3s observations. Fictional incident. Recorded, not live.

What would prove isolation?

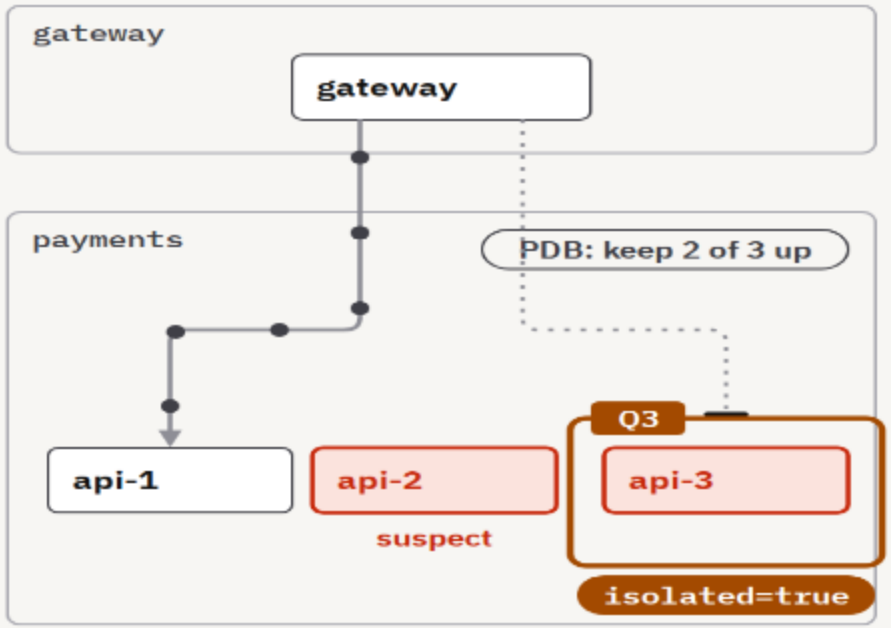


Q3 is requested.
An existing rule allows DNS.

Which allowance must change?
Name the confirming test.

Recorded k3s observations; simplified workload names. Scenario context is fictional.

What must happen before removal?

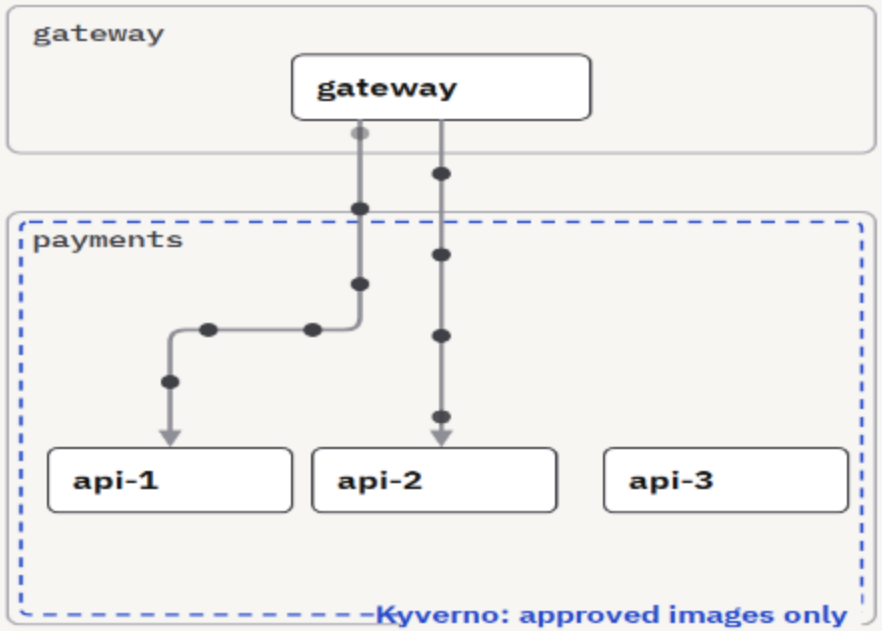


Three copies run.
Two may be affected.
Q3 blocks replacements.

Keep two healthy copies.
What evidence and capacity do you need before removal?

Recorded k3s observations; simplified workload names. Scenario context is fictional.

What would make debugging safe?

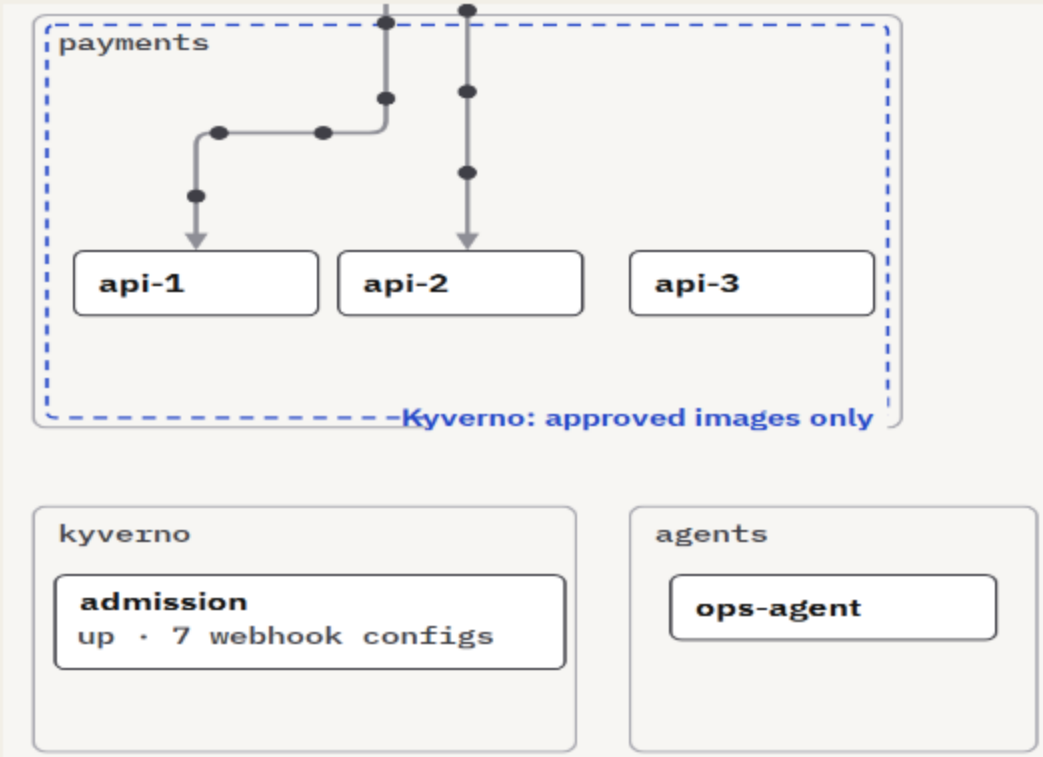


The image rule covers Pods.
Debug uses another API path.

What request needs testing?
What forensic access would you allow?

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Which authority must change?



Agent: can scale any Deployment.
Kyverno: runs as a Deployment.

What permission would you remove?
How will you test guardrail availability?

Recorded k3s observations; simplified workload names. Scenario context is fictional.

Review findings and unresolved requirements

Case	What changes the response
A	The updated image is present on multiple replicas
B	The assistant follows injected instructions through tools
C	A human executes changes outside the agent identity scope
D (lab)	Copied credential still reads Secrets after Pod quarantine

Trained model proposal

Requirement	Selected control / routing	Score
Network restriction	Privilege escalation	0.8986
Privilege escalation	Privilege escalation	0.8574
Kubernetes API access	Human review	0.5895
Rollout and expiry	Privilege escalation	0.9107

One privilege policy. Six privilege tests pass.

Which requirements lack enforcement evidence?

Passing privilege tests leave the proposal incomplete

6 / 6

Pod CREATE privilege tests

Network	Wrong control selected
API access	Human disposition required
Rollout / expiry	Wrong control selected

Record the enforcement owner and the evidence required to proceed.

Evidence for model selection

Compare the work completed and the review still required.

JEV 1.13	CLAUDE OPUS 5.5	LAYA / ZERO-SHOT
30/33	**32/33**	**16/33**
1.82 s / run	**24.18 s / run**	**0.41 s / run**
$0.00019 / run	$0.03795 / run	$0 API* / run
Guardrail generated	**Guardrail generated**	**No guardrail generated**

33 authored choices. Review/deployment excluded. *Local compute unpriced; workflow incomplete.
Small pilot; no production winner. Measure error cost and reviewer effort before selecting a model.

04

Define recovery criteria.

On page 7, name the exit test, who can lift quarantine and the rollback condition.



How evidence changes a decision

Decision record	Defensible example, not an executed response
Intent	Stop suspect traffic. Preserve two clean service copies
Initial review	Hold broad approval. Traffic and API evidence missing
New evidence	Another copy shares the image. Q3 blocks replacement
Revised plan	Preserve evidence. Verify clean capacity before removal
Recovery	Require denied suspect paths, working dependencies and authorized lift

Your environment: name one requirement, its owner and the evidence needed to proceed.

SESSION RESOURCES

Patterns to adapt across Kubernetes

github.com/mgunjan/sc2632-tabletop

Policy templates and fixture tests
Evidence capture and Quarantine levels
Four incident cases and recorded lab results

Apache-2.0 source, public repository.
Validate identity, CNI behavior and policy support on your platform.

Fallback: generated policy excerpt

kind: ValidatingPolicy
name: deny-privilege-escalation
validationActions: [Deny]

The policy rejects privileged containers.
Human review approves the generated file before deployment.

Provenance: model = none (spec supplied)

Fallback: fixture admission outcomes

Workload	Policy result
payments-api	Passes privilege and egress checks
backup-job	Would block under the egress-profile policy
report-runner	Registry violation at Audit, admitted
backup-job with exception	Egress check skips the matched exception

Case D: copied credential response

Change	Copied Kubernetes credential	Preserved access
Broad binding	Outside Secret GET/LIST: 200	Named Secret and ConfigMap: 200
Pod quarantined	Outside Secret GET/LIST: 200	Stand-in HTTP health available
RBAC narrowed	Outside Secret GET/LIST: 403	Required named GETs: 200
Old bound Pod deleted	Old credential: 401	Replacement credential: 200

Stand-in health only. External application-key rotation remains required.

Training and classical baselines

Candidate	Correct / 27	Selected / 27	Wrong selected
TF-IDF + logistic regression	20/27	8/27	0
Base Laya	12/27	2/27	0
Trained Laya	12/27	16/27	5

480 synthetic training states. Same task and runtime option order.

Small author-labelled pilot. Confidence needs independent validation.

Setup and total operating cost

Cost component	Hosted API	Local model
Setup	Keys, billing, network, workspace	Runtime, weights, device and memory
Per-run inference	Metered token charges	Owned compute and operations
Shared engineering	Compiler, tests, credentials and observability	Compiler, tests, credentials and observability
Human review	Uncertainty and unmet intent	Uncertainty and unmet intent

One extra minute of review can exceed the API cost savings.

Full comparison: quality and confidence

Metric	Jev 1.13	Opus 5.5	Laya
Correct choices	30/33	32/33	16/33
Decision latency	0.17 s HTTP	2.37 s HTTP	0.09 s in-process
Selected at score 0.6	26/33	33/33	1/33
Wrong among selected	0/26	1/33	0/1
Scenario A time/run	1.82 s	24.18 s	0.41 s
API cost/run	$0.00019	$0.03795	$0 API; compute unpriced

33 scored labels. Small pilot; confidence definitions differ. Laya generated no guardrail.